

SGSI-UNCP

Gestión de Identidades y Control de Acceso (Identity-First)

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Gestión de Identidades y Control de Acceso (Identity-First)
 - 1.1 Filosofía de Control: Zero Trust (Confianza Cero)
 - 1.2 Ciclo de Vida de la Identidad Digital
 - 1.3 Gestión de Cuentas Privilegiadas (PAM)
 - 1.4 Gestión de Acceso para Estudiantes (Alcance Específico)
 - 1.5 Control de Acceso Físico
 - 1.6 Responsabilidades
 - 1.7 Métricas de Cumplimiento
 - 1.8 Documentos Relacionados

1. Gestión de Identidades y Control de Acceso (Identity-First)

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Norma:** ISO/IEC 27001:2022 (Controles A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, A.8.4, A.8.5) **Ali-neamiento:** TRV-01 (Gestión de Identidades IdM/SSO), POL-SGSI-06 (Política de Contraseñas), POL-SGSI-05 (Dispositivos Móviles)

1.1. Filosofía de Control: Zero Trust (Confianza Cero)

La UNCP adopta un modelo de “**Nunca confiar, siempre verificar**”. El acceso a los activos de información (ERP ADESA, Campus Virtual, SIGA, recursos cloud) no depende de la ubicación física (estar en el campus), sino de la verificación sólida y continua de la identidad, el dispositivo y el contexto de la solicitud.

1.1.1. 1.1 Principios del Modelo Zero Trust en la UNCP

1. **Acceso explícito y verificado:** Toda solicitud de acceso debe ser autenticada y autorizada de forma explícita, incluso si proviene de la red interna del campus.
2. **Privilegio mínimo:** Cada usuario recibe únicamente los permisos estrictamente necesarios para cumplir su función, durante el tiempo necesario (Just-In-Time).
3. **Segmentación lógica:** El acceso a cada sistema se concede de forma individualizada (microsegmentación), impidiendo el movimiento lateral en la red.
4. **Monitoreo continuo:** Toda sesión activa debe ser monitoreada para detectar comportamientos anómalos y revocar el acceso en tiempo real si es necesario.

1.2. Ciclo de Vida de la Identidad Digital

1.2.1. 2.1 Registro y Alta (Onboarding)

Tipo de Usuario	Fuente de Datos	Método de Creación	Sistemas Asignados por Defecto
Estudiante	Sistema de Admisión (ERP ADESA)	Automatizado (sincronización IdM)	Correo Microsoft 365, Campus Virtual Moodle, Portal del Estudiante
Docente	Sistema de RRHH (SIGA)	Automatizado (sincronización IdM)	Correo Microsoft 365, VPN, Campus Virtual (rol docente), ERP ADESA (rol según facultad)
Administrativo	Sistema de RRHH (SIGA)	Automatizado (sincronización IdM)	Correo Microsoft 365, VPN, SIGA, ERP ADESA (según perfil)
Contratista / Proveedor	Solicitud manual (F-SGSI-01)	Manual por OTI con vigencia definida	Acceso VPN temporal + sistema específico del servicio
Cuenta de Servicio	Solicitud del administrador del sistema	Manual por OTI con justificación documentada	Sistema específico (sin correo, sin acceso interactivo)

Principio de Privilegio Mínimo: Todo usuario se crea con acceso nulo. Los roles y permisos se asignan por grupos (RBAC) según su perfil y unidad orgánica. No se otorgan permisos directos a nivel de usuario individual, salvo excepciones documentadas.

1.2.2. 2.2 Autenticación Robusta (MFA)

Tipo de Usuario	MFA Exigido	Método Principal	Método de Respaldo
Administrativo (acceso a sistemas críticos)	Obligatorio	Aplicación de autenticación (Microsoft Authenticator, Google Authenticator)	Códigos de respaldo (backup codes)
Docente (acceso a notas, VPN)	Obligatorio	Aplicación de autenticación o SMS institucional	Códigos de respaldo
Administradores de sistemas (OTI)	Obligatorio	Llavero FIDO2 / Token físico (hardware key) + aplicación	Códigos de respaldo + aprobador en segunda aplicación
Estudiante (acceso a Moodle, correo)	Recomendado (no obligatorio)	Aplicación de autenticación	SMS
Contratista / Proveedor	Obligatorio	Aplicación de autenticación	Códigos de respaldo

1.2.3. 2.3 Control de Acceso Dinámico (SSO + Acceso Condicional)

- **SSO (Single Sign-On):** Se implementará un Identity Provider (IdP) central (Keycloak o Azure AD B2C) que unifique la autenticación de todos los sistemas, eliminando la necesidad de múltiples credenciales y contraseñas separadas.
- **Acceso Condicional (Conditional Access):** El IdP evaluará en cada solicitud:
 - **Ubicación geográfica:** ¿El inicio de sesión proviene de una ubicación esperada?
 - **Dispositivo:** ¿Está gestionado por el MDM y cumple las políticas de salud?
 - **Riesgo de la sesión:** ¿Hay características de inicio de sesión anómalas (navegador no habitual, IP sospechosa, hora inusual)?
 - **Aplicación solicitada:** ¿El usuario tiene permiso para esta aplicación específica?
- **Acción ante riesgo elevado:** Bloqueo de la solicitud o solicitud de MFA adicional (step-up authentication).

1.2.4. 2.4 Revisión y Baja (Offboarding)

Evento	Acción Automática	Responsable	Plazo
Cese de personal administrativo	Desactivación de todas las cuentas (correo, VPN, sistemas) + reenvío de correo al jefe inmediato por 30 días	OTI (automatizado por IdM + RRHH)	Inmediato (día del cese)
Renuncia de docente	Desactivación de acceso a sistemas de notas y actas. Correo activo por 90 días para transición	OTI + Facultad	Inmediato (notificación de RRHH)
Egreso de estudiante	Desactivación de Moodle y sistemas académicos a los 6 meses de egreso. Correo activo por 1 año	OTI (automatizado)	Programado según calendario
Término de contrato de proveedor	Desactivación de cuentas temporales + VPN	OTI	24 horas tras el término
Fallecimiento	Bloqueo inmediato de todas las cuentas	OTI + RRHH	Inmediato

Revisión Trimestral de Accesos Privilegiados: - Los dueños de cada sistema deben revisar y validar la lista de usuarios con permisos elevados. - Cualquier cuenta privilegiada que no haya sido utilizada en los últimos 60 días debe ser desactivada temporalmente. - El resultado de la revisión debe documentarse en el acta del Comité de Gobierno Digital.

1.3. Gestión de Cuentas Privilegiadas (PAM)

1.3.1. 3.1 Principios

- Queda **prohibido** el uso compartido de cuentas genéricas como “admin”, “root”, “administrator” o “sa”. Todo administrador debe usar una cuenta nominativa con privilegios asignados según su rol.
- Las cuentas privilegiadas deben estar nominadas y asociadas a una persona física identificable.

1.3.2. 3.2 Acceso Just-In-Time (JIT)

- Los privilegios elevados (administración de bases de datos, cloud, servidores) no son permanentes. Se solicitan a través del sistema PAM para una tarea específica, con una ventana de tiempo definida (ej. 4 horas).
- La solicitud de elevación de privilegios debe incluir: ID de ticket de cambio, sistema objetivo, ventana de tiempo solicitada y justificación.
- Al vencerse el tiempo, los privilegios se revocan automáticamente.

1.3.3. 3.3 Registro y Auditoría

- Toda acción realizada con una cuenta privilegiada debe ser registrada (log de comandos, sesiones grabadas si es posible).
- Los logs deben enviarse al SIEM y conservarse por un mínimo de **2 años**.
- Se realizará una revisión mensual de las actividades privilegiadas para detectar anomalías.

1.4. Gestión de Acceso para Estudiantes (Alcance Específico)

Dado que el estudiante no está sujeto a las políticas obligatorias de dispositivos (POL-SGSI-05), el acceso a los sistemas académicos se gestiona de la siguiente forma:

Sistema	Autenticación	MFA	Observaciones
Campus Virtual (Moodle)	Usuario + contraseña (IdM)	Recomendado	Acceso desde cualquier dispositivo
Correo Institucional (Microsoft 365)	Usuario + contraseña (IdM)	Recomendado	Sujeto a las Políticas de Uso Aceptable de Microsoft
Portal del Estudiante	Usuario + contraseña (IdM)	Recomendado	Información académica personal
Biblioteca / Repositorio	Usuario + contraseña (IdM)	No requerido	Acceso a recursos bibliográficos
Red WiFi Institucional	Usuario + contraseña (portal cautivo)	No requerido	Tráfico cifrado (HTTPS) pero segmentado de la red administrativa

1.5. Control de Acceso Físico

1.5.1. 5.1 Acceso al Datacenter

- **Mecanismo:** Biometría (huella dactilar) + tarjeta de proximidad.
- **Horario:** 24/7 solo para personal autorizado de la OTI. Fuera de horario laboral, requiere autorización del Jefe de la OTI.
- **Registro:** Automático en el sistema de control de acceso + bitácora física (F-SGSI-06).
- **Videovigilancia:** Cámara en la puerta de ingreso con grabación continua.

1.5.2. 5.2 Acceso a Áreas Administrativas

- Oficinas que manejan datos confidenciales (RRHH, Tesorería, Registros Académicos) deben permanecer cerradas con llave fuera del horario laboral.
- El acceso de personal de limpieza debe realizarse en presencia de personal de seguridad patrimonial.

1.5.3. 5.3 Acceso de Visitantes

- Todo visitante debe registrarse en recepción, portar identificación visible y ser acompañado por un empleado de la UNCP.

1.6. Responsabilidades

Rol	Responsabilidad
Usuario	Proteger sus credenciales; no compartir cuentas; reportar actividades sospechosas; usar MFA.
Jefe Inmediato	Solicitar altas/bajas de su personal de forma oportuna; revisar accesos de su equipo trimestralmente.
OTI (Soporte)	Gestionar el IdM; atender solicitudes de alta/baja; configurar MFA y SSO.
OTI (Seguridad)	Administrar el sistema PAM; monitorear accesos privilegiados; revisar logs.
Oficial de Seguridad	Definir políticas de acceso; autorizar excepciones; supervisar el cumplimiento.
Dueño del Activo	Validar y aprobar los accesos a los sistemas bajo su responsabilidad.

1.7. Métricas de Cumplimiento

Indicador	Meta	Frecuencia	Fuente
% de usuarios con MFA activado (personal)	100 %	Mensual	IdM / Azure AD
% de cuentas privilegiadas sin actividad > 60 días	0 %	Mensual	Sistema PAM
Tiempo medio de desactivación al cese	< 2 horas	Por evento	Sistema de tickets
% de accesos revisados trimestralmente	100 %	Trimestral	Actas de revisión
Número de accesos no autorizados detectados	0	Mensual	SIEM

1.8. Documentos Relacionados

Código	Nombre
POL-SGSI-05	Política de Seguridad para Dispositivos Móviles del Personal
POL-SGSI-06	Política de Contraseñas y Autenticación Segura
P-SGSI-02	Marco de Respuesta a Incidentes (CSIRT)

Código	Nombre
F-SGSI-01	Formato de Solicitud de Alta/Baja/Cambio de Acceso
F-SGSI-03	Formato de Baja de Usuario y Devolución de Activos
